

AppSec Orchestrator — Session Change Log

Summary of major changes made during onboarding & setup session

Generated: 2026-06-12

1. Created the onboarding report

A complete developer onboarding document was generated at **docs/project_onboarding.md**, covering purpose, tech stack, folder structure, frontend/backend/database architecture, authentication flow, API flow, build & deployment, dependencies, security concerns, missing documentation, entry points, config files, environment variables, and technical debt.

Type: New file | **Impact:** Documentation only, no runtime change.

2. Fixed the database startup crash

The app crashed on launch with `sqlite3.OperationalError: unable to open database file`. The cause was a relative SQLite path in **.env** that overrode the correct absolute path built by **backend/config.py**.

File: **.env**

Removed the hard-coded relative `DATABASE_URL` so the app falls back to the absolute path computed in `config.py`.

```
- DATABASE_URL=sqlite:///./instance/appsec.db
+ # Leave DATABASE_URL unset - config.py builds the
+ # correct absolute path automatically
```

Result: SQLite now resolves and creates `instance/appsec.db` correctly on startup.

3. Hardened the ZIP upload handler

Three related fixes were applied to **backend/api/projects.py** in the project-creation endpoint, based on the `MAX_SCAN_FILE_SIZE` / upload analysis.

3a. Stream uploads instead of loading into memory

Previously `zip_file.read()` pulled the entire upload (up to 200 MB) into a single bytes object, then wrapped it in `io.BytesIO` — spiking RAM to ~2× the ZIP size. Now the size is measured via the stream's `seek()/tell()` (metadata only) and `zipfile.ZipFile` reads directly from the upload stream, which Werkzeug already spools to a temp file on disk.

3b. Fixed the misleading size-limit message

The error said “*max 50MB*” while the real limit (`MAX_UPLOAD_SIZE`) is 200 MB. The message now derives the number from `config`.

```
- "ZIP file is too large (max 50MB)."
```

```
+ f"ZIP file is too large (max {max_mb}MB)."
```

3c. Hardened the path-traversal check

The old `startswith()` containment test had a sibling-directory weakness (e.g. `/uploads/1/proj_evil` passes against `/uploads/1/proj`). Replaced with a proper `parents`-based containment check.

```
+ if member_path != project_root_resolved and \
+     project_root_resolved not in member_path.parents:
+     return jsonify({...path traversal...}), 400
```

Also added `import io` at the module top and removed the inline import.

4. Intentionally left unchanged

- **MAX_SCAN_FILE_SIZE** stays at 512 KB — confirmed appropriate; the per-file `stat()` check in `file_scanner.py` already enforces it before any read.
- **MAX_CONTENT_LENGTH** (200 MB) remains the outer WSGI-level guard that rejects oversized requests before the handler runs.

5. Files touched this session

File	Change
<code>docs/project_onboarding.md</code>	Created (onboarding report)
<code>.env</code>	Removed relative <code>DATABASE_URL</code>
<code>backend/api/projects.py</code>	Streamed upload, fixed message, hardened traversal
<code>docs/session_changes.pdf</code>	Created (this document)

Restart `python run.py` to load the code changes.